Documentation centralisée – Resilience Alpha

Ce document centralise la documentation technique, opérationnelle et de gouvernance du démonstrateur local de paiement fictif et de cyber-résilience. Il sert de point d'entrée unique pour le projet, tout en conservant les documents détaillés dans le dossier `docs/` et la procédure de crise dans `rag/procedure_crise.md`.

1. Contexte du projet

Resilience Alpha est un démonstrateur local de paiement fictif et de cyber-résilience. Toutes les données et tous les scénarios sont synthétiques ; aucune donnée bancaire réelle n'est utilisée. Le projet simule un environnement de paiement avec authentification, surveillance, IA de détection et procédures de reprise.

Le système vise à démontrer :

- un parcours de paiement nominal ;
- une dégradation contrôlée par injection d'incident ;
- une détection fondée sur des métriques et un modèle d'anomalie ;
- une remédiation approuvée et vérifiée ;
- des preuves de reprise et de gouvernance visibles dans la pile locale.

2. Architecture et flux

Le prototype est composé d'un dashboard React/Tailwind, d'un WAF, d'un service d'authentification, d'une API FastAPI, d'une base PostgreSQL, de Prometheus, Loki, Grafana et d'un composant AIOps. L'architecture impose un réseau interne Compose, avec seulement deux ports hôte exposés par défaut.

Le flux nominal suit le parcours :

- 1. authentification de l'opérateur ;
- 2. soumission du paiement via le dashboard ;
- 3. validation dans l'API ;
- 4. écriture de la transaction en base ;
- 5. publication des événements et métriques ;
- 6. observation et reprise par le moteur AIOps si une anomalie est détectée.

Les détails complets sont dans architecture.md.

3. Installation et démarrage local

Prérequis :

- Docker Desktop avec Compose v2 ;
- Python 3.12 pour les tests et scripts ;
- un réseau de laboratoire autorisé ;

- un PC Hôte avec accès à la webcam USB et au port série ESP8266 (pour le composant d'authentification faciale).

Le démarrage suit les étapes suivantes :

```
Copy-Item .env.example .env
# compléter les secrets locaux, notamment EXERCISE_TOKEN, REMEDIATION_TOKEN, FACE_AGENT_TOKEN

docker compose --env-file .env config --quiet
docker compose --env-file .env up --build -d
```

Le composant caméra doit ensuite être démarré séparément sur le PC Hôte, avec téléversement du firmware ESP8266 et lancement de l'agent. La reconnaissance faciale utilise des images de référence chiffrées et les modèles OpenCV Zoo téléchargés localement.

Pour le mode démonstration avec un PC attaquant distinct, le point d'accès de laboratoire doit être utilisé avec des règles de pare-feu explicitement contrôlées. La configuration exacte est détaillée dans le fichier README principal et dans le dossier `docs/`.

4. Sécurité, conformité et risques

Le prototype applique plusieurs principes de sécurité de démonstration :

- secrets locaux non versionnés ;
- rôles et jetons distincts pour l'opérateur, l'attaque de test et la remédiation ;
- réseau Compose interne ;
- ports hôte limités aux interfaces de laboratoire ;
- journalisation et observabilité séparées ;
- exclusion des secrets et des clés du dépôt et des archives de livraison.

Les points de vigilance sont documentés de manière explicite :

- réseau HTTP local uniquement ;
- jetons de démonstration, pas mécanisme d'identité de production ;
- manque de MFA, de rotation de clés, de contrôle d'accès robuste et de sauvegarde validée ;
- limite du prototype vis-à-vis d'une conformité réglementaire réelle.

Les travaux sur les risques, la continuité et la conformité sont consignés dans risk-pca-pra.md et security-operations.md.

5. Procédure d'incident et reprise

Le scénario de résilience contrôlé suit le principe suivant :

- 1. un opérateur réalise un paiement nominal ;
- 2. un PC Attaquant autorisé injecte une panne contrôlée ;
- 3. l'API répond 503 et n'écrit pas les transactions échouées ;
- 4. Prometheus et les métriques AIOps identifient l'anomalie ;
- 5. le moteur AIOps déclenche une remédiation autorisée ;

- 6. la reprise est vérifiée par une transaction de contrôle ;
- 7. l'état opérationnel est remis dans un état nominal.

Le dossier d'opérations et la procédure de reprise sont décrits dans incident-response.md et rag/procedure_crise.md.

6. Tests, preuves et démonstration

Les tests automatisés portent notamment sur :

- le cycle complet d'incident et de reprise ;
- la détection par Isolation Forest ;
- l'état consolidé de l'API et du dashboard ;
- les limites de seuil, les faux positifs et les faux négatifs.

La commande de validation typique est :

```
py -3.12 -m pip install -r api\requirements.txt -r api\requirements-dev.txt
py -3.12 -m pip install -r aiops\requirements.txt
py -3.12 -m pytest api\tests aiops\test_detector.py -q
```

Le cadre détaillé de recette, preuves et démonstration est disponible dans testing-and-demo.md.

7. Traçabilité du cahier des charges

Le projet documente la correspondance entre les exigences fonctionnelles, les livrables attendus et les éléments de preuve. Cette traçabilité est essentielle avant la soutenance et pour vérifier ce qui est réellement démontré par l'environnement local.

Voir requirements-traceability.md.

8. Dossiers de livraison et livrables

Le sujet demande un dossier d'ingénierie PDF, une présentation, un clip court, une archive sans secrets et un démonstrateur exécuté sur deux machines. Le dépôt préparé ici contient le contenu technique et les prérequis de ces livrables.

Le fichier de référence pour les rendus demandés est deliverables.md.

9. Documents détaillés

- architecture.md
- deliverables.md
- face-auth-and-iot.md
- incident-response.md
- ml-experiment.md
- requirements-traceability.md
- risk-pca-pra.md

- security-operations.md
- testing-and-demo.md
- ../rag/procedure_crise.md

10. Règle de consultation

Pour un lecteur de la documentation, la séquence recommandée est :

- 1. ce document central ;
- 2. architecture.md ;
- 3. requirements-traceability.md ;
- 4. testing-and-demo.md ;
- 5. risk-pca-pra.md ;
- 6. les documents opérationnels complémentaires.

Cette organisation permet de conserver la documentation technique détaillée sans disperser la compréhension globale du projet.